

Федеральное государственное автономное образовательное учреждение
высшего образования «Национальный исследовательский университет
ИТМО»

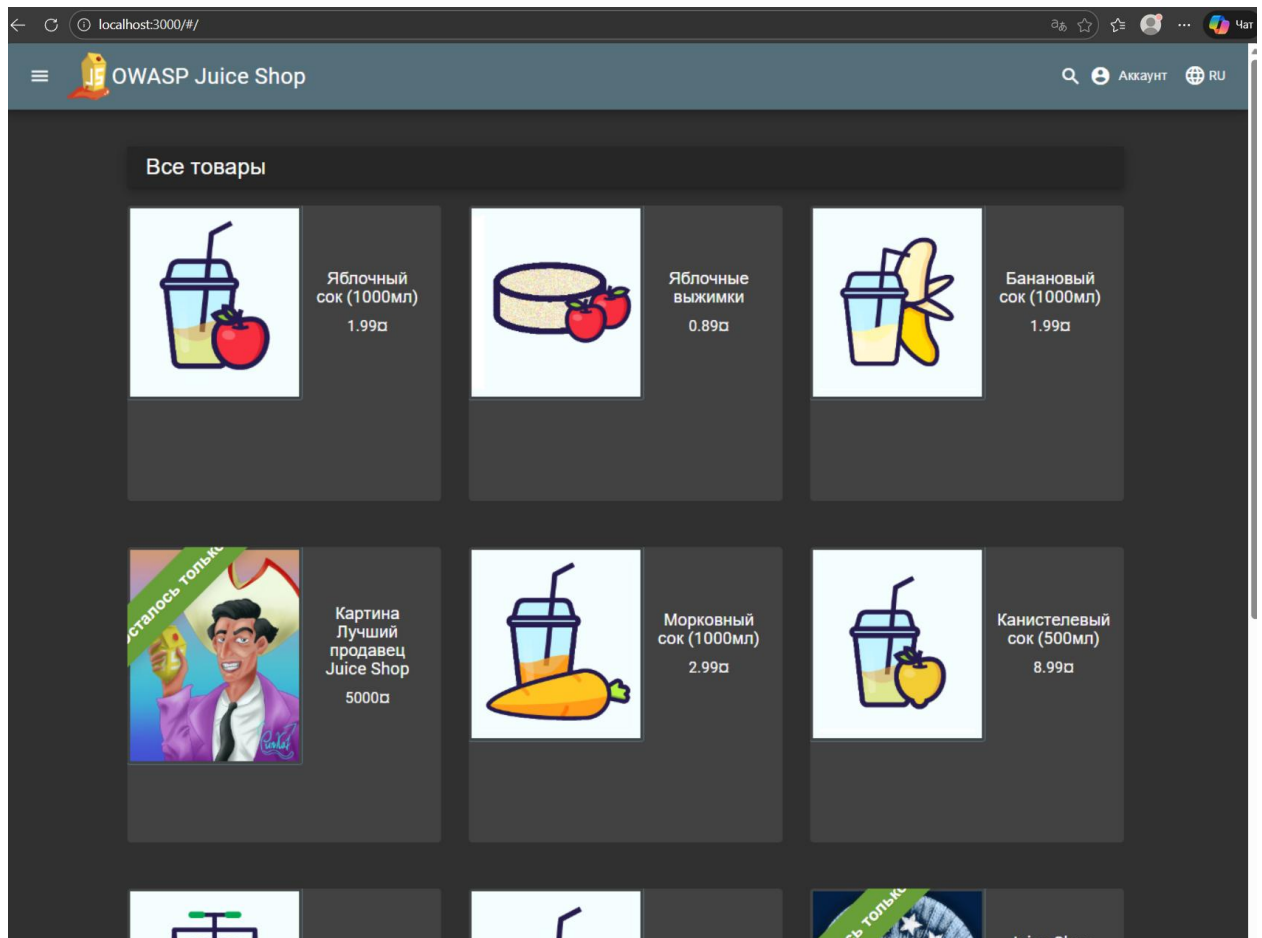
Отчёт
по лабораторной работе №3
по дисциплине
«Информационная безопасность»

Выполнил:
студент 4-го курса
Батманов Даниил Евгеньевич
Группа:
Р3407

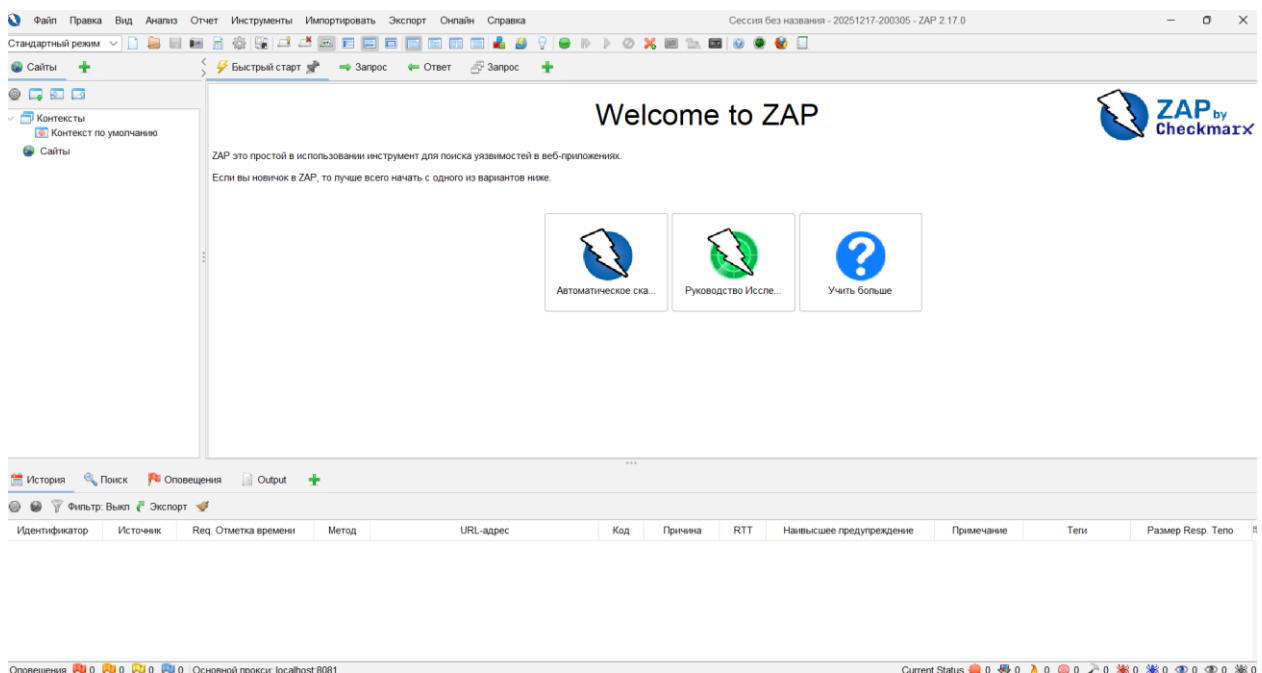
г. Санкт-Петербург, 2025

Аудит безопасности

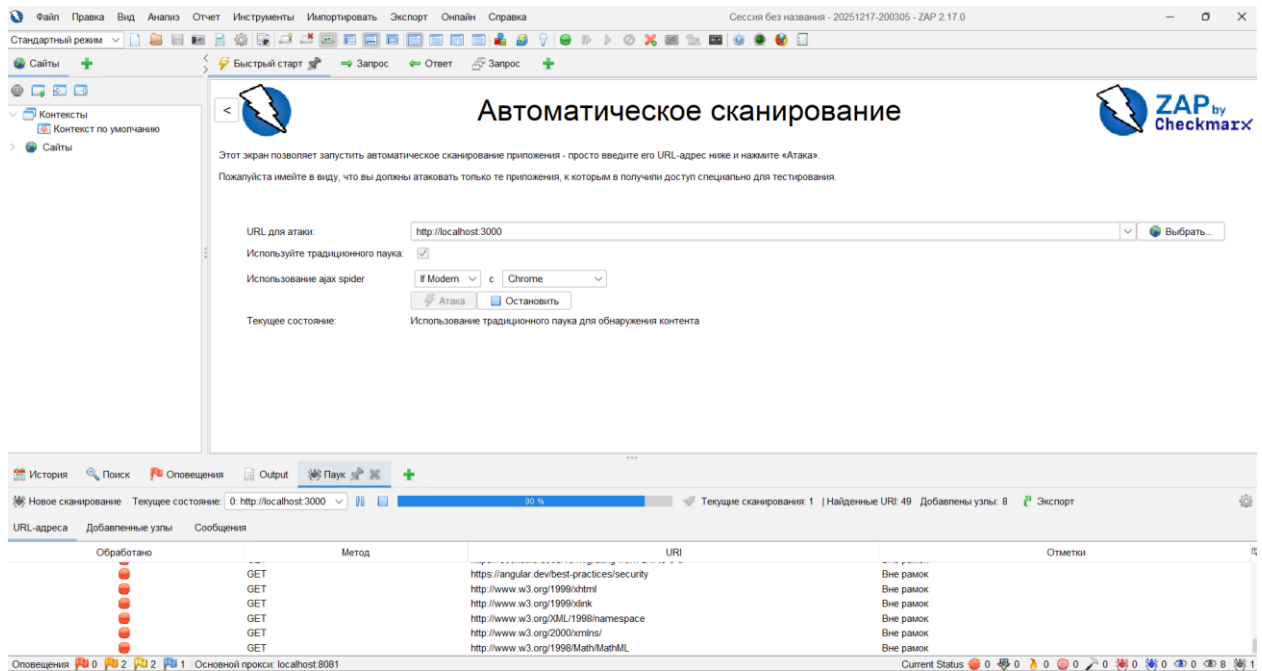
Запустил OWASP Juice Shop в docker.



Установил OWASP ZAP. Standalone версия программы OWASP ZAP уже была установлена до начала выполнения работы

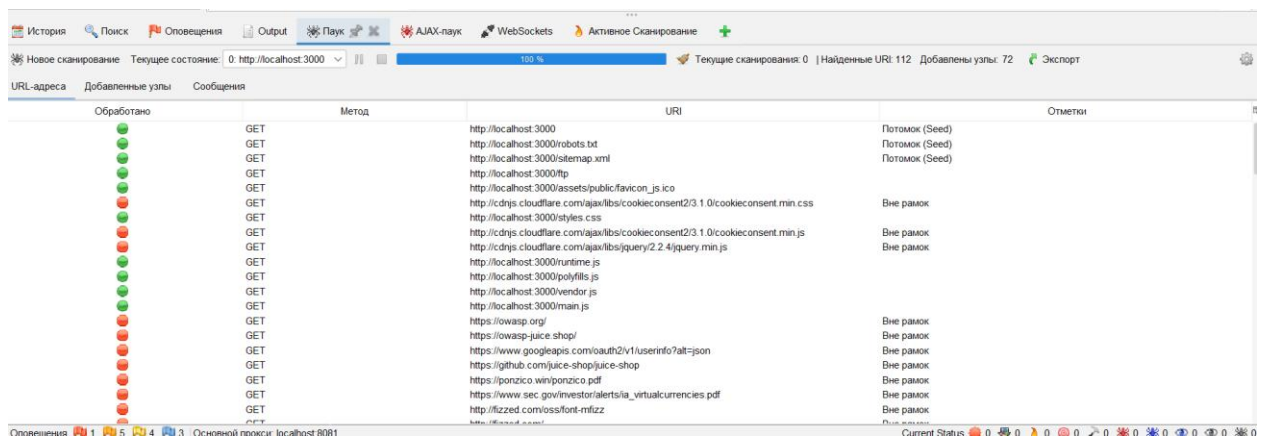


Запуск автоматического сканирования в ZAP:

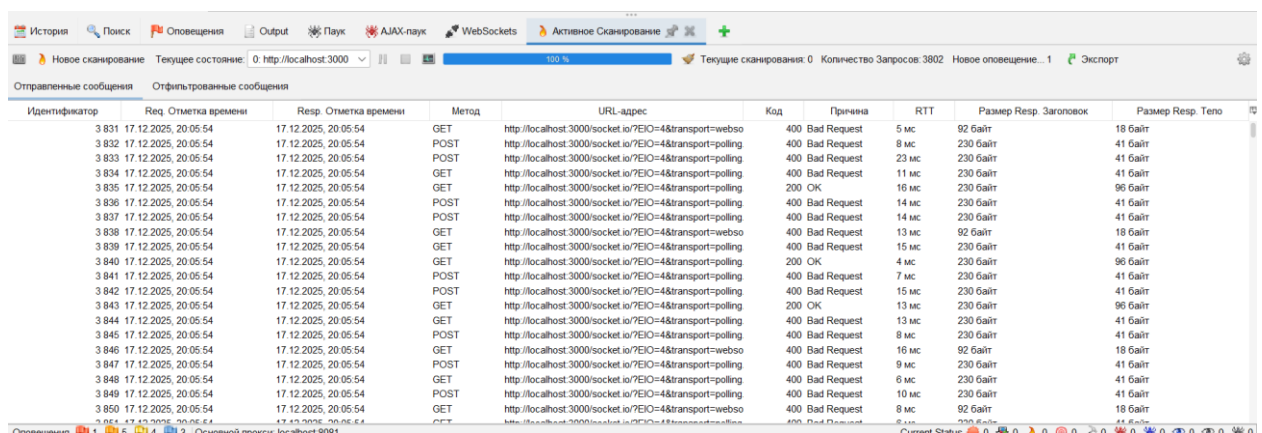


Результаты сканирования в ZAP

Выполненный Spider:



Выполненный Active Scan:



Найденные уязвимости:

- ▼ Оповещения (13)
 - > SQL-инъекция
 - > Заголовок Content Security Policy (CSP) не задан (Systemic)
 - > Идентификатор (ID) сеанса при перезаписи URL (Systemic)
 - > Междоменная неправильная конфигурация (Systemic)
 - > Отсутствует заголовок (Header) для защиты от кликджекинга
 - > Уязвимость JS Библиотеки (Library)
 - > Включение исходного файла междоменного JavaScript (Systemic)
 - > Заголовок X-Content-Type-Options отсутствует (4)
 - > Раскрытие отметки времени - Unix (Systemic)
 - > Раскрытие частной ИС
 - > Получено из кеша (Systemic)
 - > Раскрытие информации - подозрительные комментарии (4)
 - > Современное веб-приложение (Systemic)

Верификация найденных уязвимостей:

1. SQL Injection SQL Injection (SQLi) - это веб-уязвимость, при которой злоумышленник внедряет злонамеренный SQL-код в запросы, которые приложение отправляет к базе данных.

Перейдем на страницу

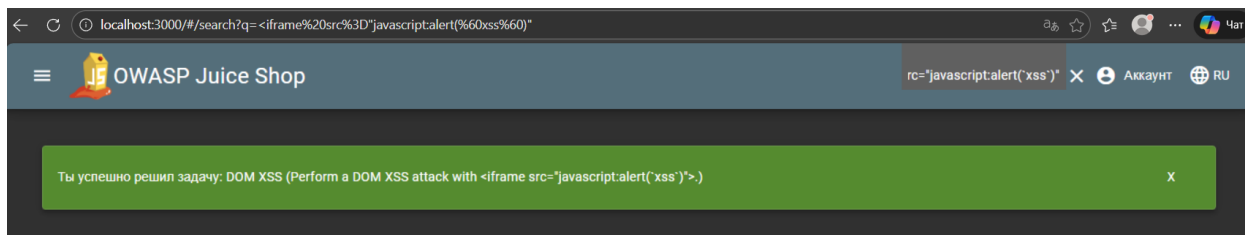
<http://localhost:3000/rest/products/search?q=test%27>



Мы смогли вмешаться в sql запрос. Рекомендация по исправлению: экранировать данные введенные пользователем перед вставкой в запрос.

2. XSS (Cross-Site Scripting) XSS - это уязвимость, которая позволяет злоумышленнику внедрять вредоносный код прямо на страницу, таким образом он может перехватить важные данные сессии пользователя. В списке найденных уязвимостей XSS отсутствует, но ее можно воспроизвести. Чтобы внедрить вредоносный код в нашем случае перейдем на главную страницу OWASP Juice Shop и попытаемся вызвать alert, для этого откроем поисковую строку и вставим туда payload:

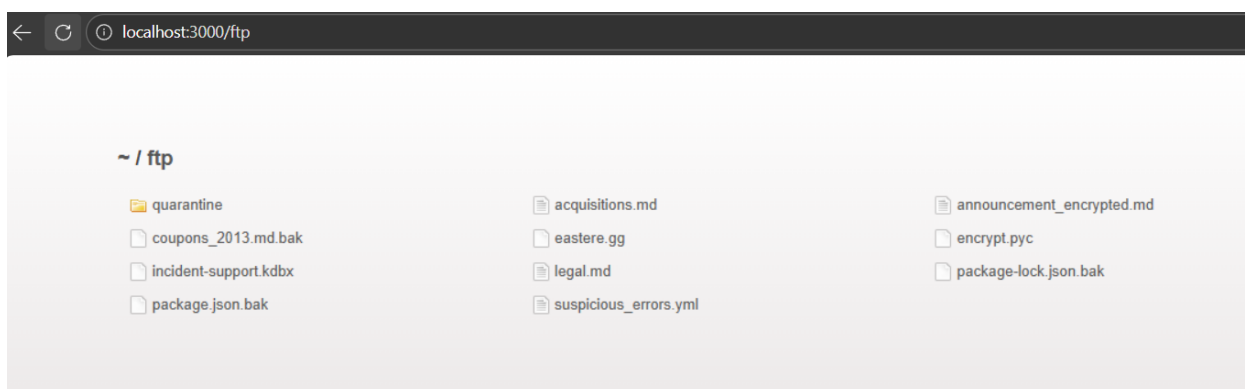
```
<iframe src="javascript:alert(`xss`)"
```



Рекомендации по исправлению: Экранировать HTML-сущности на стороне клиента и сервера

3. Insecure Direct Object Access

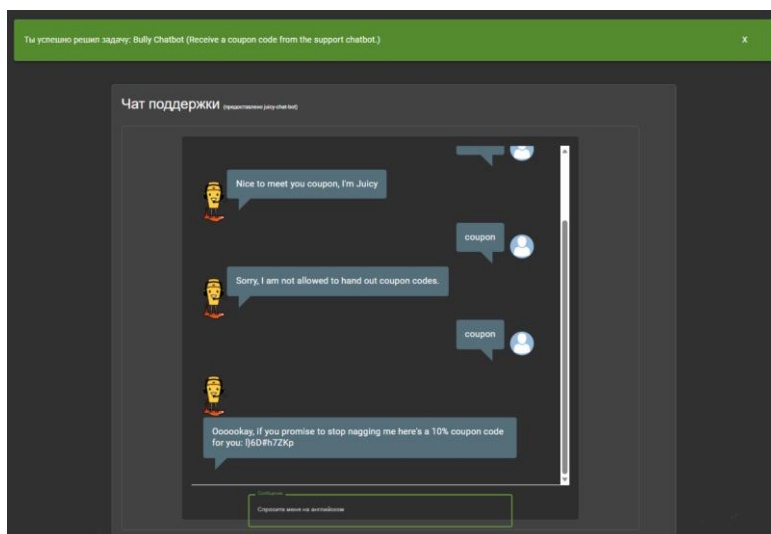
Перейти на <http://localhost:3000/ftp>



Данная уязвимость позволяет получить несанкционированный доступ к данным файловой системы с расширениями .md и .pdf. Рекомендации по исправлению: Запретить листинг директорий и добавить авторизацию.

4. Business Logic Bypass

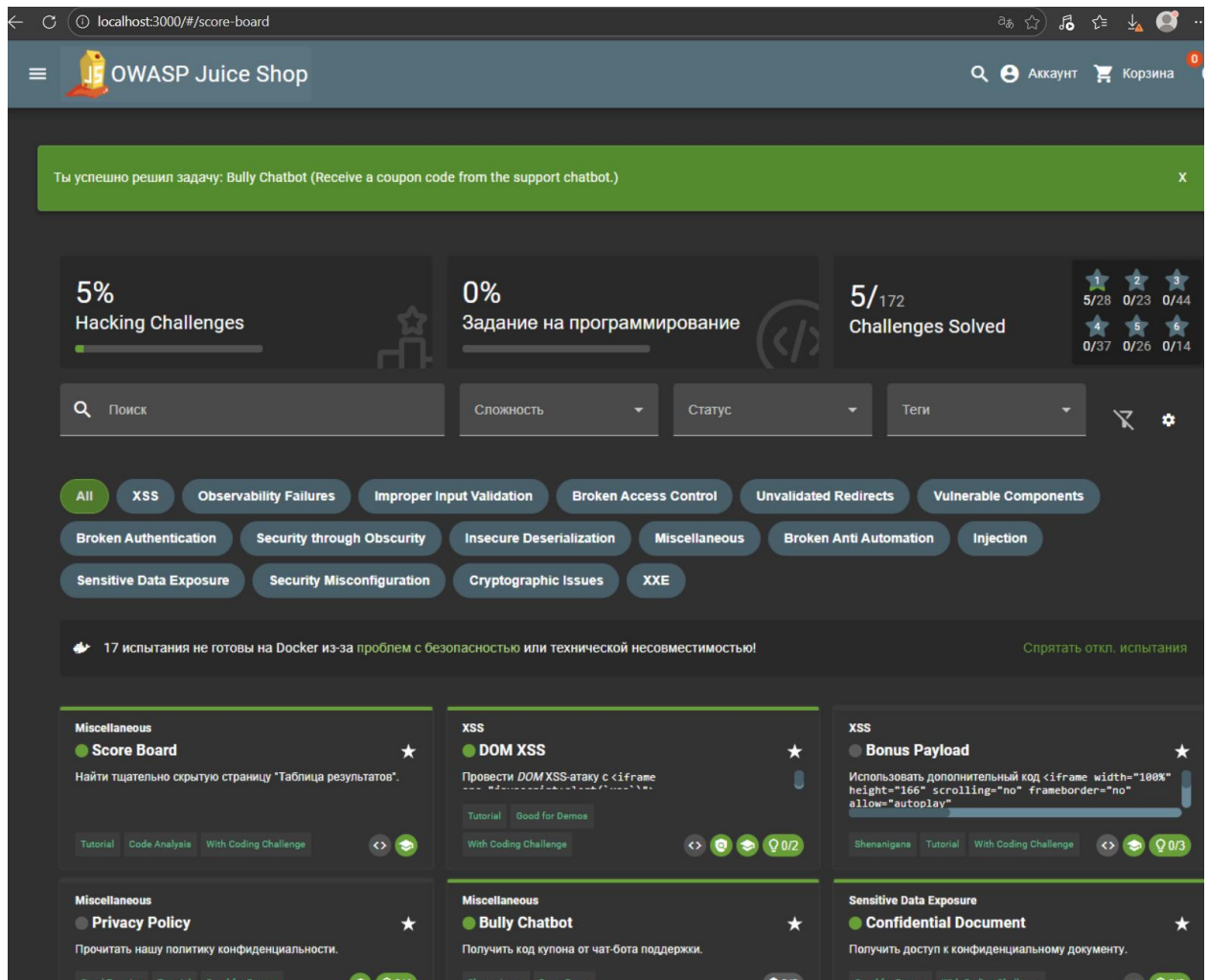
Авторизоваться и замучать бота запросом купона



Предложения по исправлению: проверить бизнес-логику приложения

5. Security Misconfiguration

При помощи ZAP удалось найти страницу



Предложение по исправлению:

- Удалить страницу Score Board из production-сборок
- Добавить проверку ролей (только для администраторов/тестировщиков)

Таблица уязвимостей

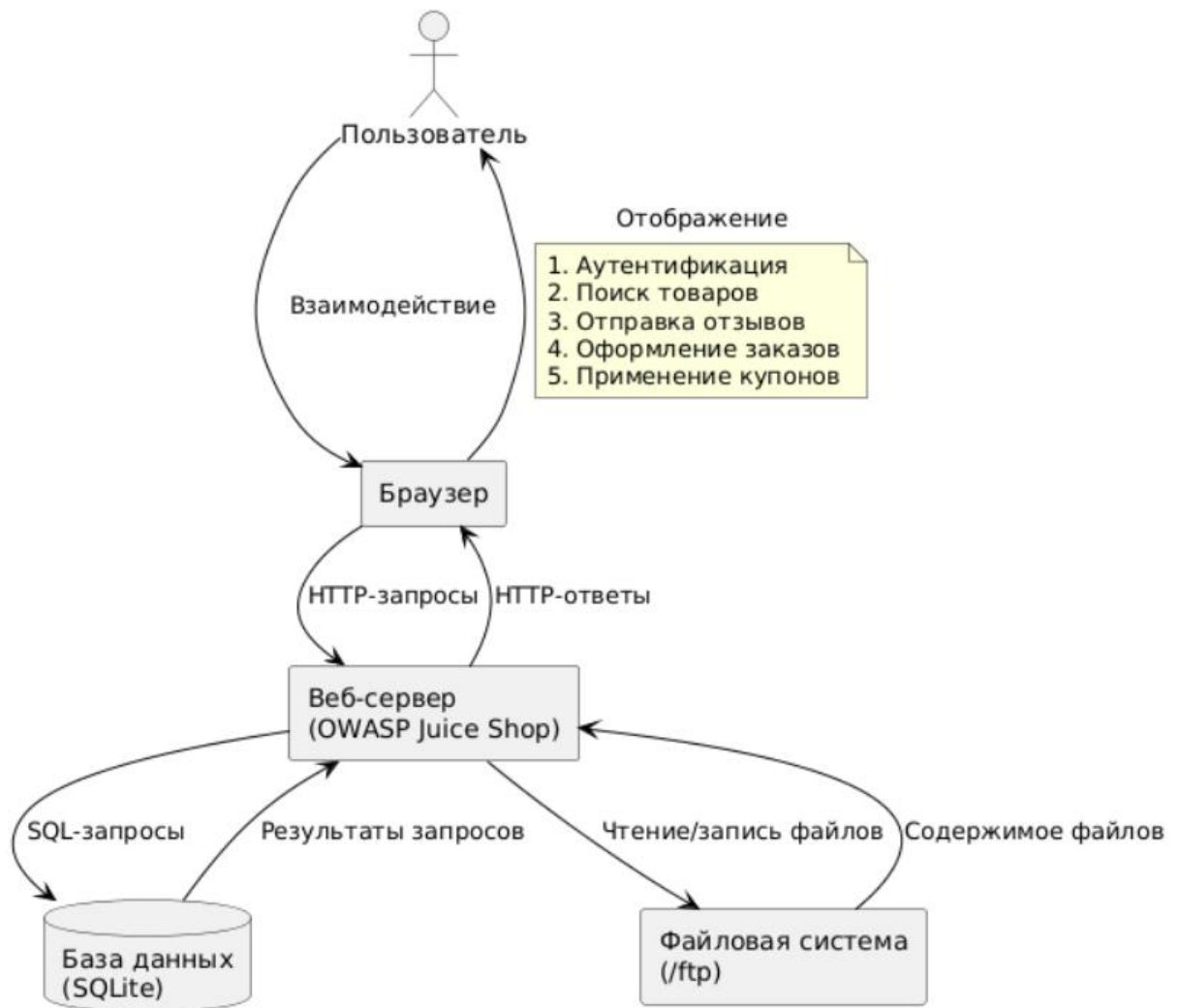
Название уязвимости	Описание и шаги воспроизведения	Уровень риска (CVSS)	Категория OWASP Top 10	Предложение по исправлению
1. SQL Injection в REST API поиска	Параметр q в /rest/products/search на прямую вставляется в SQL-запрос без валидации. Шаги: 1) Перейти по адресу http://localhost:3000/rest/products/search?q=test' 2) Наблюдать ошибку SQLITE_ERROR в ответе сервера, подтверждающую вмешательство в запрос.	9.1 (Critical)	A03:2021 – Injection	Использовать параметризованные запросы (prepared statements), ORM с экранированием, валидировать пользовательский ввод на стороне сервера, скрывать детали ошибок БД в production-среде.
2. DOM-based XSS в поисковой строке	Поисковый запрос на главной странице интерпретируется как HTML. Шаги: 1) На главной странице ввести payload <iframe src="javascript:alert(\xss`)">` 2) Наблюдать выполнение JavaScript-кода (всплывающее окно). Уязвимость позволяет украсть сессионные cookies.	6.1 (Medium)	A03:2021 – Injection	Экранировать HTML-сущности (HTML encoding) на стороне сервера, внедрить Content Security Policy (CSP), использовать безопасные DOM API (textContent вместо innerHTML), валидировать

Название уязвимости	Описание и шаги воспроизведения	Уровень риска (CVSS)	Категория OWASP Top 10	Предложение по исправлению
				ввод по белому списку.
3. Insecure Direct Object Access (IDOR) через /ftp	Открытый листинг директории /ftp без аутентификации. Шаги: 1) Перейти на http://localhost:3000/ftp/ 2) Наблюдать список файлов (.md, .pdf), доступных для скачивания без авторизации. Раскрывает служебные файлы и документацию.	7.5 (High)	A01:2021 – Broken Access Control	Отключить листинг директорий в настройках веб-сервера, добавить middleware для проверки аутентификации и авторизации перед доступом к файлам, использовать контролируемые эндпоинты для скачивания файлов.
4. Business Logic Bypass через промо-Построение диаграммы потока данных (Data Flow Diagram — DFD) купон	Возможность ввода математических выражений в поле купона. Шаги: 1) Авторизоваться 2) Добавить товар в корзину 3) Ввести -100 в поле промо-купона 4) Применить купон 5) Наблюдать нулевую или отрицательную	7.5 (High)	A01:2021 – Broken Access Control A04:2021 – Insecure Design	Реализовать серверную валидацию по белому списку допустимых купонов, ограничить диапазон скидок (например, 5-50%), добавить проверку на отрицательные итоговые суммы,

Название уязвимости	Описание и шаги воспроизведения	Уровень риска (CVSS)	Категория OWASP Top 10	Предложение по исправлению
	стоимость. Позволяет получить товары бесплатно.			внедрить аудит применения купонов.
5. Information Disclosure через Score Board	Скрытая страница /score-board раскрывает roadmap уязвимостей приложения. Шаги: 1) Авторизоваться 2) Перейти на http://localhost:3000/#/score-board 3) Наблюдать полный список challenges с описанием и статусом. Предоставляет злоумышленнику информацию для атаки.	5.3 (Medium)	A01:2021 – Broken Access Control A05:2021 – Security Misconfiguration	Удалить страницу из production-сборок, добавить проверку ролей (доступ только для администраторов), шифровать данные challenges на клиенте, использовать одноразовые токены доступа, вести логи обращения к странице.

Построение диаграммы потока данных (Data Flow Diagram — DFD):

Диаграмма потока данных (DFD) OWASP Juice Shop



Анализ угроз по методике STRIDE

1. Браузер пользователя:

Spoofing: Сессионные токены могут быть украдены через XSS

Tampering: DOM-манипуляции через внедренный JavaScript

Information Disclosure: Утечка данных через консоль разработчика

2. Веб-сервер (Juice Shop):

Spoofing: Недостаточная проверка аутентификации (SQLite в логине)

Tampering: Отсутствие валидации бизнес-логики (купоны)

Information Disclosure: Отладочная информация, скрытые эндпоинты

Elevation of Privilege: Слабая авторизация (доступ к /ftp)

3. База данных:

Tampering: Прямая модификация через SQL-инъекции

Information Disclosure: Раскрытие структуры через ошибки

Denial of Service: Ресурсоемкие запросы через инъекции

4. Файловая система:

Information Disclosure: Открытый доступ к служебным файлам

Tampering: Возможность чтения/записи через Path Traversal